You said:

exec(1).pyc
Code

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Worked for 3m 46s

ChatGPT said:

Análise de segurança do arquivo `exec(1).pyc`

MALWARE CONFIRMADO Risco muito alto

Veredito: o arquivo é malicioso. A análise estática do bytecode revela funcionalidades concretas de roubo de credenciais, coleta de dados pessoais e exfiltração para servidores externos. O código também contém recursos de espionagem e mecanismos que interferem no funcionamento do Windows.

A categoria principal é **Infostealer (ladrão de informações)**, com funcionalidades adicionais de spyware.

1. Identificação do arquivo

O arquivo analisado apresenta as seguintes características:

Propriedade	Resultado
Nome	`exec(1).pyc`
Tamanho	150.358 bytes
Formato	Bytecode Python compilado
Versão	CPython 3.13
SHA-256	`ef5b86710d76e7e73370db0ba54f79d0ad80fb0d6290ec8aabd5380d84105aa5`

O conteúdo foi descompilado em memória para inspeção das instruções e constantes. **O arquivo não foi executado durante a análise.**

2. Identificação do malware

Entre as strings incorporadas ao bytecode, encontrei:

- `RedTiger St34l3r`
- `RedTiger St34l3r - github.com/loxy0dev/RedTiger-Tools`

Isso indica que o programa se identifica como **RedTiger St34l3r**. A identificação é baseada no próprio conteúdo do arquivo, não em uma atribuição independente de autoria.

Também existem diversas funções com nomes ofuscados e funções vazias usadas para dificultar a leitura do código.

3. Coleta de informações do computador

O programa coleta informações sobre o ambiente da vítima, incluindo:

- Nome do computador e nome do usuário.
- Nome de exibição da conta.
- Versão e informações do sistema operacional.
- Processador, memória RAM e placa de vídeo.
- Informações de discos e unidades.
- Endereço MAC e identificadores de hardware.
- Identificadores da placa-mãe e BIOS.
- Endereço IP público e endereço IP local.
- Localização aproximada, país, cidade e provedor de internet.

Esses dados são organizados em um relatório chamado `System Info.txt`.

A coleta de informações do equipamento é uma etapa típica de identificação da vítima por um infostealer.

4. Roubo de contas e tokens do Discord

O arquivo contém uma função dedicada à localização e extração de tokens do Discord.

Ela procura dados em instalações do Discord e em diferentes navegadores. Entre as informações coletadas estão:

- Tokens de autenticação.
- Nome de usuário e nome de exibição.
- Identificador da conta.
- Endereço de e-mail e telefone.
- Informações sobre Nitro.
- Estado de autenticação multifator.

- Informações de pagamento.
- Códigos de presentes.

O programa também consulta a API do Discord utilizando os tokens encontrados e armazena os resultados em um arquivo chamado `Discord Accounts`.

Além disso, há um componente JavaScript que tenta modificar a instalação desktop do Discord, escrevendo um arquivo `index.js` em diretórios internos do aplicativo. O objetivo aparente é executar código dentro do cliente Discord e interceptar informações de autenticação e pagamento.

Isso representa uma capacidade de comprometimento de contas, embora a execução bem-sucedida dependa do ambiente e das condições de instalação.

5. Roubo de informações dos navegadores

Esta é uma das funcionalidades mais graves encontradas.

O programa procura perfis de diversos navegadores, incluindo Chrome, Edge, Opera, Opera GX, Brave e outros navegadores baseados em Chromium.

Ele acessa bancos de dados locais dos navegadores e procura informações nas tabelas:

Banco ou tabela	Informação procurada
`Login Data`	Usuários, endereços dos sites e senhas
`Cookies`	Cookies de autenticação e sessões
`History`	Histórico de navegação
`downloads`	Histórico e caminhos de downloads
`Web Data`	Dados de cartões de crédito

Também encontrei código que utiliza DPAPI do Windows e AES-GCM para descriptografar informações protegidas dos navegadores.

Isso é especialmente perigoso porque cookies e sessões podem permitir acesso a contas mesmo sem o conhecimento da senha original.

O programa ainda tenta encerrar processos dos navegadores antes de acessar os respectivos bancos de dados.

6. Roubo de contas Roblox

Existe outra rotina dedicada à coleta de cookies do Roblox.

Ela procura o cookie de autenticação `.ROBLOSECURITY` em diferentes navegadores e consulta a API do Roblox para obter informações da conta associada.

Entre os dados procurados estão:

- Cookie de autenticação.
- Nome de usuário.
- Nome de exibição.
- Identificador da conta.
- Avatar.
- Saldo de Robux.
- Informações de assinatura Premium.

Os resultados são armazenados em um arquivo chamado `Roblox Accounts.`

Portanto, o malware também possui capacidade específica de comprometimento de contas Roblox.

7. Captura de webcam e tela

O código contém duas funcionalidades adicionais de espionagem.

Webcam: utiliza `cv2.VideoCapture(0)` para tentar acessar a câmera do computador, capturar uma imagem e armazená-la como `Webcam.png`.

Captura de tela: utiliza `PIL.ImageGrab.grab()` para capturar a tela e armazenar a imagem como `Screenshot.png`.

Ambas as imagens são incluídas no conjunto de informações coletadas.

A captura efetiva depende da disponibilidade dos dispositivos e das permissões do sistema.

8. Interferência no funcionamento do Windows

Também foram encontrados comportamentos destinados a dificultar a intervenção da vítima e o acesso a ferramentas de segurança.

Entre eles:

- Tentativa de encerrar o Gerenciador de Tarefas (`taskmgr.exe`).
- Alteração do Registro do Windows para desabilitar o Gerenciador de Tarefas.
- Modificação do arquivo `hosts` para bloquear domínios relacionados a ferramentas de análise e antivírus, incluindo VirusTotal e Avast.
- Tentativa de bloquear teclas por meio da biblioteca `keyboard` .

Esses comportamentos são indicadores adicionais de intenção maliciosa e de tentativa de dificultar a investigação ou remoção do programa.

9. Exfiltração dos dados roubados

Esta é uma das evidências mais fortes da natureza maliciosa do arquivo.

O programa reúne os dados coletados em um arquivo ZIP em memória. O nome previsto para o arquivo contém o identificador `RedTiger` e o nome do usuário da vítima.

Em seguida, o malware:

1. Consulta a API do serviço GoFile para obter um servidor de upload.
2. Envia o arquivo ZIP para esse servidor.
3. Obtém o endereço de download do arquivo enviado.
4. Prepara uma mensagem com informações sobre a vítima e os dados coletados.
5. Envia essa mensagem por meio de um webhook do Discord.

Também foi possível identificar e descriptografar offline uma URL de webhook incorporada ao programa. O endereço aponta para o domínio `discord.com` . O token completo não será reproduzido aqui.

Isso demonstra que o programa possui um mecanismo definido para retirar os dados da máquina e disponibilizá-los remotamente.

10. Observações sobre o comportamento real

É importante distinguir funcionalidades implementadas de funcionalidades apenas mencionadas no código.

Encontrei módulos que são efetivamente chamados pelo fluxo principal, incluindo os responsáveis pela coleta de informações do sistema, tokens do Discord, dados dos navegadores, cookies do Roblox, webcam e captura de tela.

Por outro lado, algumas categorias mencionadas no relatório, como carteiras de criptomoedas, possuem funções vazias nesta versão analisada. Portanto, não considero comprovado o roubo de carteiras cripto.

O código também contém configuração `auto_buy_nitro: false`. Apesar de existir lógica relacionada à compra de presentes Nitro, essa opção aparece desativada na configuração encontrada.

A análise foi estática: não executei o programa, portanto não posso afirmar que todas as operações de coleta e envio seriam concluídas com sucesso em qualquer computador. Isso não altera a classificação, pois as funcionalidades maliciosas estão claramente implementadas.

11. Veredito final

CLASSIFICAÇÃO: MALWARE

Infostealer

Categoria secundária: Spyware, com mecanismos de evasão e interferência no sistema.

Confiança da classificação: Muito alta.

O arquivo apresenta funcionalidades concretas para roubar senhas, cookies, tokens de autenticação, dados de cartões, informações de contas Discord e Roblox, além de capturar imagens da tela e da webcam. Também possui mecanismos para enviar os dados coletados a servidores externos.

Conclusão: `exec(1).pyc` não é um programa benigno. Trata-se de um malware do tipo **Infostealer**, que também apresenta comportamento de spyware. Recomendo não executá-lo em nenhuma circunstância.

Caso já tenha sido executado: desconecte o computador da rede, faça a verificação e limpeza a partir de um ambiente confiável e, utilizando outro dispositivo, altere as senhas das contas afetadas, revogue sessões do Discord e Roblox, invalide sessões dos navegadores e entre em contato com o banco caso dados de cartões possam ter sido expostos.

You said:

Qual é a categoria principal deste malware?

ChatGPT said:

A categoria principal deste malware é **Infostealer (ladrão de informações)**.

Sua principal função é roubar credenciais, senhas, cookies, tokens de autenticação e dados pessoais, além de exfiltrá-los para servidores externos.

Também apresenta funcionalidades secundárias de **Spyware**, como captura de tela e webcam.